



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Bastionado de Redes y Sistemas

TEMA 1

INTRODUCCIÓN AL BASTIONADO

Alberto Diéguez Álvarez

Tabla de contenido

TAREA BRS01	2
¿Qué te pedimos que hagas?	2
¿Qué debes hacer?	2
1. Contexto de la organización	2
2. Análisis básicos de riesgos	3
3. Medidas de bastionado	4
4. Plan director de seguridad (visión general)	5
5. Reflexión sobre Zero Trust.....	6

TAREA BRS01

¿Qué te pedimos que hagas?

En esta unidad, hemos conocido los fundamentos del bastionado: su origen, necesidad, principales amenazas, y el papel que desempeñan los planes de seguridad dentro de la estrategia de defensa de una organización. También has aprendido la importancia del análisis de riesgos como punto de partida y has descubierto el nuevo paradigma Zero Trust, que representa una evolución respecto a los modelos clásicos basados en la confianza del perímetro.

Tu tarea consiste en simular la aplicación práctica de estos conceptos en un caso real o inventado, diseñando las bases de un plan inicial de bastionado para una microempresa.

Tu objetivo será analizar su situación actual y proponer medidas básicas de bastionado, apoyándote en los contenidos vistos en esta unidad.

¿Qué debes hacer?

1. Contexto de la organización

a. Describe brevemente la empresa: sector, número de empleados y recursos tecnológicos disponibles.

Para este ejemplo voy a usar una empresa con sede en León, la empresa es: <https://printermania.es/> Una empresa nacida en el año 2005 que aporta soluciones tanto en impresión como en diseño gráfico, además de rotulación, copistería...

Para determinar su **número de empleados** dado que esa información no es pública y al ser un negocio local, supongamos que alrededor de **10 personas** entre gestores de pedidos, personal para atender la tienda, para preparar pedidos...

Recursos tecnológicos disponibles:

- Ordenadores de oficina.
- Impresoras industriales.
- Almacenamiento local o en la nube para los ficheros de los clientes.
- Disponen de página web.
- Router para conexión a internet en el local.

b. Identifica los tres activos más críticos y explica por qué lo son para el negocio.

1. **Plataforma de pedidos online**, donde se pueden alojar archivos, login de usuarios... Es crítico ya que es información de clientes, tanto datos personales como archivos...
2. **Impresoras y ordenadores locales**. Es crítico dado que las impresoras y los ordenadores estarían conectadas en red, o tal vez compartiendo ficheros en red, además en los ordenadores locales podría haber información sensible de clientes, sesiones activas, cookies... Consiguiendo acceso igual se podría obtener datos de clientes, información sensible, incluso datos bancarios.
3. **Registro de clientes**, al recibir pedidos, tienen información de clientes/empresas, sus logos, archivos...

2. Análisis básicos de riesgos

a. Elabora una tabla sencilla donde se reflejen las amenazas y vulnerabilidades más probables, indicando:

- Impacto potencial
- Probabilidad de ocurrencia
- Nivel de riesgo (bajo, medio o alto)

Amenaza	Vulnerabilidad	Impacto	Probabilidad	Riesgo
Ataque ransomware	Equipos sin actualizar	Alto	Media	Alto
Acceso no autorizado al sitio web	Contraseñas débiles, falta de doble autenticación	Alto	Media	Alto
Phising a empleados	Poca formación de empleados, correo sin filtros...	Alto	Alta	Alto
Fuga de datos de clientes	Permisos de los usuarios	Alto	Media	Alto

b. Señala cuál consideras el riesgo más crítico y justifica tu decisión.

Diría en primer lugar **Ransomware**, ya que detendría la producción de la tienda, además de la posible pérdida de datos de usuarios y habría problemas con la Ley de protección de datos.

Por otro lado, también me resulta muy crítico el acceso no autorizado al sitio web, ya que si pudieran acceder como administradores podrían (no sé cómo está gestionado) obtener datos bancarios de los clientes.

3. Medidas de bastionado

a. Propón al menos cinco medidas concretas de bastionado adaptadas a la organización. Clasifícalas en:

- **Medidas técnicas:** configuración segura, actualizaciones, redes, contraseñas, etc.
- **Medidas organizativas:** políticas, formación, copias de seguridad, gestión de incidentes...

Medidas técnicas:

- Copias de seguridad automáticas y si es posible en la nube, de la base de datos de clientes, asegurando la recuperación de todos los datos ante un ataque o un fallo de hardware.
- Habilitar la doble autenticación para la página web.
- Actualizaciones de sistemas operativos, programas para la gestión de la tienda, actualizaciones de los drivers y firmware de las impresoras...
- Cifrar datos sensibles de los clientes.

Medidas organizativas:

- Política de contraseñas seguras.
- Formación del personal en materia de ciberseguridad (phishing, protocolos...)
- Definir un procedimiento de actuación ante incidentes.
- Definir una política de copias de seguridad y la recuperación de datos en casos de incidencias.

b. Justifica brevemente cada medida.

Empezando por las **medidas técnicas**. Intento tener respuesta antes cualquier ataque, como por ejemplo al tener copias de seguridad de la base de datos, se podría rápidamente recuperar todos los pedidos, datos de clientes etc...

Al tener los equipos actualizados estamos evitando vulnerabilidades.

Al cifrar datos de los clientes estamos evitando filtraciones de datos sensibles como contraseñas, datos personales...

Para las **medidas organizativas**. Intento tener un plan para mitigar cualquier posible vulnerabilidad. Como vimos en las medias, al tener contraseñas seguras, estamos evitando o complicando los ataques por fuerza bruta.

Al formar a los empleados, nos aseguraremos de que entiendan cómo funcionan los ataques de phishing y como poder evitarlos.

Y al definir políticas de actuación, nos aseguramos de tener una rápida respuesta ante cualquier ataque.

4. Plan director de seguridad (visión general)

a. Explica cómo estructurarías un plan director de seguridad en tu empresa.

No hay una única manera de estructurar o implementar el plan director de seguridad y además varía según el sector. Yo lo que haría sería primero **estructurar** los puntos del negocio, es decir, personal, maquinaria de producción, datos, servidores web, redes... para tener un esquema global de todos los activos de la empresa. Y luego **definir** responsables, planes...

b. Incluye sus principales apartados: objetivos, alcance, responsables, seguimiento y mejora continua.

- **Objetivos:** Proteger los datos de los clientes y asegurar la producción.
- **Alcance:** Redes, datos, sistemas y equipos de la empresa.
- **Responsables:** Gerente, responsable de TI, responsable de seguridad...
- **Seguimiento:** Auditorias, revisiones del estado de seguridad, reporte interno.
- **Mejora continua:** Planear, hacer, verificar y actuar. Revisar medidas, actualizar documentación...

5. Reflexión sobre Zero Trust

a. Indica qué principios del modelo Zero Trust podrían aplicarse a tu empresa y cómo.

Nunca confiar y siempre verificar, todos los accesos deben autenticarse y autorizarse incluso dentro de la red de la empresa.

Principio de mínimo privilegio, los empleados deben tener el acceso estrictamente necesario.

b. Reflexiona sobre las dificultades prácticas que encontrarías para implantar este modelo en un entorno real de pequeña empresa.

Lo primero y lo habitual sería los recursos limitados, tanto por tiempo como por dinero.

Luego también a veces la complejidad técnica, dado que los empleados pueden carecer de esa experiencia.

El mantenimiento continuo, las revisiones y el seguimiento de los procesos requieren una dedicación constante.

Bibliografía:

- <https://printermania.es/>
- <https://chatgpt.com/share/6911311f-a2f4-800e-9c48-42812477e15c>
- <https://www.zscaler.com/resources/security-terms-glossary/what-is-zero-trust>
- <https://www.netskope.com/es/security-defined/what-is-zero-trust>
- <https://securityscorecard.com/blog/what-is-zero-trust-architecture>
- <https://www.fortinet.com/resources/cyberglossary/how-to-implement-zero-trust>
- <https://learn.microsoft.com/es-es/security/zero-trust/>
- <https://cloud.google.com/security>
- <https://adl.incibe.es/>
- <https://www.ccn-cert.cni.es/ens.html>
- <https://csrc.nist.gov/publications/detail/sp/800-207/final>

NOTAS:

Al ser la primera tarea agradecería feedback de la misma, para saber si la he enfocado bien, si me he quedado corto en algún punto o en que podría mejorar.